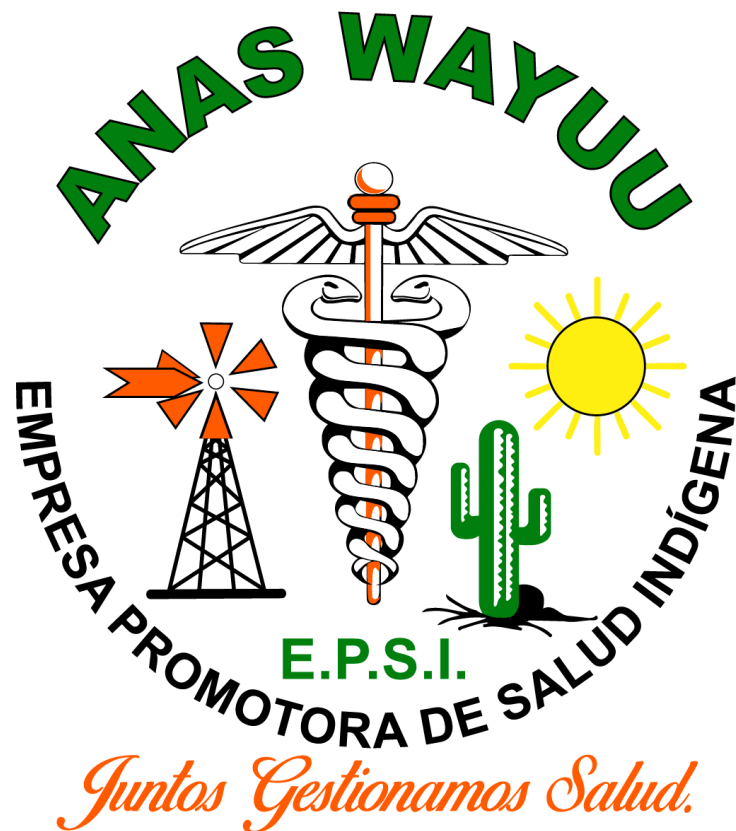


PROCEDIMIENTO DE AUDITORÍA INTERNA



Maicao, La Guajira

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	2 de 23		

CONTENIDO

1. OBJETIVO GENERAL.....	4
2. ALCANCE	4
3. DEFINICIONES.....	4
4. MARCO LEGAL.....	6
5. DESCRIPCIÓN DE ACTIVIDADES	6
5.1 FASE DE PREPARACIÓN E INICIO	7
5.1.1 Revisión del Programa de Auditorías y Matriz de Priorización	7
5.1.2 Designación del Auditor Líder y Equipo Auditor	7
5.1.3 Comunicación inicial a los procesos auditados.....	7
5.2 FASE DE PLANIFICACIÓN DETALLADA	8
5.2.1 Recolección y revisión de información preliminar	8
5.2.2 Elaboración del Plan de Auditoría.....	8
5.2.3 Aprobación y distribución del Plan de Auditoría.....	9
5.3 FASE DE EJECUCIÓN DE LA AUDITORÍA.....	9
5.3.1 Reunión de apertura.....	9
5.3.2 Obtención de evidencia de auditoría	9
5.3.3 Evaluación y análisis de la evidencia	10
5.3.4 Registro de hallazgos de auditoría	10
5.4 FASE DE CIERRE Y REPORTE	10
5.4.1 Reunión de cierre	10
5.4.2 Elaboración del Informe de Auditoría.....	11
5.4.3 Aprobación y distribución del informe	11
5.5 FASE DE ACCIONES CORRECTIVAS Y SEGUIMIENTO.....	12
5.5.1 Elaboración de planes de acción por parte del proceso auditado.....	12
5.5.2 Seguimiento a la implementación de acciones	12
5.5.3 Verificación de eficacia de las acciones correctivas.....	12
5.6 FASE DE CIERRE DE LA AUDITORÍA	13
5.6.1 Actualización de registros y archivos de auditoría	13

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	3 de 23		

5.6.2 Retroalimentación y mejora del proceso de auditoría	13
6. CRITERIOS DE PRIORIZACIÓN DEL PROGRAMA ANUAL DE AUDITORÍAS.....	13
7. FRECUENCIA.....	16
8. RESPONSABILIDADES PARA LAS AUDITORÍAS INTERNAS	17
9. DISPOSICIONES FINALES.....	19
10. ENTRADAS	19
11. MATERIALES NECESARIOS	20
12. PRODUCTOS O RESULTADOS ESPERADOS	20
13. DOCUMENTOS Y REGISTROS.....	20
14. RESPONSABLE POR LA SOCIALIZACIÓN DE ESTOS PROCESOS.....	20
15. RESPONSABLES POR LA EJECUCIÓN	21
16. CONTROL DE CAMBIOS.....	21
17. ANEXO	22

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	4 de 23		

1. OBJETIVO GENERAL

Establecer la metodología, criterios y responsabilidades para planificar, ejecutar, reportar y dar seguimiento a las auditorías internas del Sistema de Gestión de Seguridad de la Información de la EPSI Anas Wayuu, con el fin de evaluar de manera sistemática, independiente y objetiva el grado de conformidad del SGSI con los requisitos de la Norma ISO/IEC 27001:2022, los controles del Anexo A, la normativa aplicable y los lineamientos institucionales; así como verificar la eficacia de los controles implementados, identificar oportunidades de mejora y asegurar la mejora continua del sistema.

2. ALCANCE

Este procedimiento aplica a todas las auditorías internas del Sistema de Gestión de Seguridad de la Información (SGSI) de la EPSI Anas Wayuu, independientemente de su alcance, frecuencia o tipo. Comprende la planificación, preparación, ejecución, reporte, cierre y seguimiento de auditorías realizadas sobre los procesos, activos de información, controles del Anexo A de la ISO/IEC 27001:2022, requisitos legales y regulatorios, así como a cualquier dependencia, área, sistema, proveedor o servicio que participe en el tratamiento de información institucional o que pueda afectar la confidencialidad, integridad y disponibilidad de la información de la EPSI.

Incluye además la coordinación con los auditados, la gestión de hallazgos y la verificación de la eficacia de las acciones tomadas.

3. DEFINICIONES

- **Acción Correctiva:** Actividad implementada para eliminar la causa raíz de una no conformidad detectada con el fin de evitar su recurrencia.
- **Auditado:** Persona, área, dependencia, proceso o proveedor que recibe la auditoría y debe demostrar el cumplimiento de los requisitos del SGSI.
- **Auditor Líder:** Persona competente designada para gestionar y coordinar la planificación, ejecución y seguimiento de la auditoría interna del SGSI.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	5 de 23		

Nota: Cuando el auditor líder sea un tercero externo, deberá ser formalmente designado por la EPSI Anas Wayuu y cumplir plenamente los requisitos de independencia, competencia técnica y ausencia de conflicto de interés.

- **Auditoría Interna:** Proceso sistemático, independiente y documentado para obtener evidencias objetivas y evaluarlas de manera objetiva con el fin de determinar el grado de cumplimiento de los criterios de auditoría establecidos para el SGSI.

Nota: Cuando la auditoría sea realizada por un tercero externo que actúe en nombre de la EPSI Anas Wayuu, este debe cumplir los mismos criterios de independencia, competencia y confidencialidad establecidos para los auditores internos, y su actuación se considera equivalente a una auditoría interna.

- **Competencia del Auditor:** Conocimientos, habilidades técnicas, experiencia y comportamiento profesional necesarios para realizar una auditoría de forma eficaz conforme a ISO 19011.
- **Criterios de Auditoría:** Conjunto de políticas, procedimientos, requisitos de la Norma ISO/IEC 27001:2022, controles del Anexo A, requisitos legales, regulatorios y demás directrices que son utilizados como referencia para evaluar la conformidad durante la auditoría.
- **Equipo Auditor:** Grupo de auditores competentes encargados de realizar la auditoría interna. Pueden incluir auditores internos, auditores en formación o expertos técnicos.

Nota: Los miembros del equipo auditor externos deberán firmar compromisos de confidencialidad y protección de datos conforme a las políticas de la EPSI Anas Wayuu.

- **Evidencia de Auditoría:** Registros, declaraciones de hechos o información verificable obtenida durante la auditoría y que se utilizan para determinar si los criterios de auditoría se cumplen.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	6 de 23		

- **Hallazgo de Auditoría:** Resultado de la evaluación de la evidencia de auditoría frente a los criterios de auditoría. Puede ser una conformidad, no conformidad, oportunidad de mejora y fortalezas.
- **Mejora Continua:** Actividad recurrente para mejorar el desempeño del SGSI y asegurar su conveniencia, adecuación y eficacia en la preservación de la confidencialidad, integridad y disponibilidad de la información.
- **No Conformidad:** Incumplimiento de un requisito del SGSI, de ISO/IEC 27001:2022, de los controles del Anexo A, de un requisito legal, contractual o de un procedimiento interno aplicable.
- **Plan de Auditoría:** Documento que describe el alcance, objetivos, criterios, equipos auditores, procesos a auditar, recursos, cronograma y actividades necesarias para la ejecución de la auditoría interna.

4. MARCO LEGAL

NORMA	DESCRIPCIÓN
NTC ISO IEC 27001	Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de Gestión de la Seguridad de la Información. Requisitos.
GTC ISO IEC 27002	Seguridad de la información, ciberseguridad y protección de la privacidad. Controles de seguridad de la información.
NTC ISO IEC 27005	Tecnología de la Información. Técnicas de Seguridad. Gestión del Riesgo en la Seguridad de la Información.
NTC ISO IEC 27701	Extensión de las normas ISO/IEC 27001 e ISO/IEC 27002 para la gestión de privacidad de la información.

5. DESCRIPCIÓN DE ACTIVIDADES

Se describen a continuación las actividades necesarias para la correcta ejecución de una auditoría interna al Sistema de Gestión de Seguridad de la Información (SGSI) de la EPSI

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	7 de 23		

Anas Wayuu. Su propósito es garantizar que cada auditoría se realice de forma sistemática, objetiva y basada en riesgos, siguiendo los principios establecidos por la ISO 19011 y los requisitos de la norma ISO/IEC 27001:2022.

Este desarrollo paso a paso establece responsabilidades, métodos, tiempos estimados y criterios de control que aseguran la calidad, trazabilidad y eficacia del proceso auditor, promoviendo la mejora continua del SGSI y la protección de la información institucional.

5.1 FASE DE PREPARACIÓN E INICIO

5.1.1 Revisión del Programa de Auditorías y Matriz de Priorización

El Auditor Líder revisa el Programa Anual de Auditorías y la Matriz de Priorización para confirmar el proceso o área a auditar, la prioridad asignada y el periodo en el que debe ejecutarse la auditoría.

Tiempo estimado: 0,5 días hábiles.

5.1.2 Designación del Auditor Líder y Equipo Auditor

El Representante de la Dirección designa formalmente al Auditor Líder y, en conjunto con él, define la conformación del equipo auditor, asegurando la independencia, competencia técnica y ausencia de conflicto de interés.

Tiempo estimado: 1 día hábil.

5.1.3 Comunicación inicial a los procesos auditados

El Auditor Líder envía una comunicación formal (correo u otro medio institucional) a los responsables del proceso a auditar, informando: objetivo, alcance, criterios, fechas tentativas, posibles requerimientos de información y miembros del equipo auditor. Se recomienda enviar esta comunicación con la debida antelación para permitir preparación del área auditada.

Tiempo estimado: Emitir comunicación al menos 4 días hábiles antes de la fecha de inicio de la auditoría.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	8 de 23		

5.2 FASE DE PLANIFICACIÓN DETALLADA

5.2.1 Recolección y revisión de información preliminar

El equipo auditor recopila y revisa documentos relevantes: políticas, procedimientos, manuales, matrices de riesgo, inventarios de activos, informes de auditorías previas, indicadores, registros de incidentes y cualquier otra información necesaria para comprender el contexto del proceso auditado.

Tiempo estimado: 2 a 3 días hábiles (según alcance y complejidad).

5.2.2 Elaboración del Plan de Auditoría

Con base en la información preliminar, el Auditor Líder elabora el Plan de Auditoría que incluye:

- Objetivo(s) de la auditoría.
- Alcance (procesos, sedes, sistemas y periodo a evaluar).
- Criterios de auditoría (ISO/IEC 27001:2022, controles del Anexo A, requisitos legales, políticas internas, etc.).
- Metodología, métodos y técnicas de auditoría.
- Cronograma de actividades (entrevistas, revisión documental, pruebas, reuniones).
- Responsabilidades del equipo auditor.
- Recursos requeridos (accesos, salas, herramientas, conectividad, etc.).

Las actividades descritas en este apartado se articulan directamente con el FO-860-24 Plan de auditoría, el cual sirve como herramienta operativa para documentar los elementos anteriores. Este formato debe ser diligenciado por el Auditor Líder durante la fase de planificación y actualizado conforme avance el proceso, garantizando coherencia entre lo planificado, lo ejecutado y lo reportado en el informe final de auditoría.

Tiempo estimado: 1 a 2 días hábiles.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	9 de 23		

5.2.3 Aprobación y distribución del Plan de Auditoría

El Plan de Auditoría se presenta al Representante de la Dirección para su aprobación. Una vez aprobado, se comparte con los responsables del proceso auditado, con el fin de asegurar claridad sobre el alcance, fechas y requerimientos.

Tiempo estimado: 1 día hábil para revisión y aprobación.

5.3 FASE DE EJECUCIÓN DE LA AUDITORÍA

5.3.1 Reunión de apertura

En la fecha de inicio, el Auditor Líder realiza una reunión de apertura con los responsables del proceso auditado y, cuando aplique, con representantes de la Dirección. En esta reunión se:

- Presenta el equipo auditor.
- Confirma objetivo, alcance y criterios de la auditoría.
- Revisa el cronograma y la logística.
- Aclaran dudas iniciales.

Tiempo estimado: 30 a 60 minutos.

5.3.2 Obtención de evidencia de auditoría

El equipo auditor aplica las técnicas definidas (entrevistas, revisión documental, observación, pruebas, muestreo), para obtener evidencia objetiva, suficiente y pertinente que permita evaluar el cumplimiento de los criterios de auditoría.

Actividades típicas:

- Entrevistas con responsables y usuarios clave.
- Revisión de registros, informes, bitácoras, reportes de incidentes.
- Observación de actividades operativas y configuraciones de sistemas.
- Muestreo de evidencias según criticidad y riesgos.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	10 de 23		

Tiempo estimado: se establece según alcance de la auditoría.

5.3.3 Evaluación y análisis de la evidencia

El equipo auditor analiza la evidencia recolectada, comparándola frente a los criterios de auditoría. Se identifican conformidades, fortalezas, no conformidades y oportunidades de mejora. El análisis debe ser objetivo y trazable.

Tiempo estimado: Según el tiempo establecido en el plan de auditoría.

5.3.4 Registro de hallazgos de auditoría

Los hallazgos se documentan utilizando los formatos establecidos por el SGSI, registrando como mínimo:

- Descripción del hallazgo.
- Evidencias que lo soportan.
- Requisito incumplido o referencia normativa.
- Potencial impacto en la confidencialidad, integridad y disponibilidad.

El Formato FO-860-25-Lista de verificación de auditorías constituye una herramienta fundamental para apoyar la labor del equipo auditor durante la ejecución de la auditoría interna del SGSI. Este formato permite organizar los criterios de auditoría, registrar evidencias objetivas, documentar hallazgos preliminares y asegurar un seguimiento sistemático de cada requisito evaluado. Su uso garantiza coherencia, trazabilidad y consistencia en la evaluación, facilitando la consolidación de resultados y la elaboración del informe final.

Tiempo estimado: Según el tiempo establecido en el plan de auditoría.

5.4 FASE DE CIERRE Y REPORTE

5.4.1 Reunión de cierre

Al finalizar la evaluación, el Auditor Líder realiza una reunión de cierre con los responsables del proceso para:

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	11 de 23		

- Presentar los hallazgos preliminares.
- Aclarar dudas respecto a evidencias y requisitos.
- Acordar tiempos para la presentación de planes de acción.

Tiempo estimado: 45 a 90 minutos.

5.4.2 Elaboración del Informe de Auditoría

El Auditor Líder consolida los resultados en un informe de auditoría que debe incluir, como mínimo:

- Datos generales de la auditoría (fecha, proceso, auditor líder, equipo auditor).
- Objetivo, alcance y criterios.
- Resumen ejecutivo.
- Descripción de hallazgos (no conformidades, oportunidades de mejora, fortalezas).
- Conclusiones sobre la conformidad y eficacia del SGSI en el proceso auditado.

El FO-860-22 Informe de auditoría Interna es la herramienta estandarizada que debe utilizar el Auditor Líder para documentar de manera estructurada los resultados de cada auditoría interna del SGSI. Este formato facilita la presentación clara y coherente del objetivo, alcance, criterios, evidencias, hallazgos, análisis y conclusiones, asegurando uniformidad en la comunicación de los resultados y permitiendo su integración efectiva en los procesos de seguimiento, acciones correctivas y mejora continua. Su adecuado diligenciamiento garantiza la trazabilidad del proceso auditor y la calidad del reporte final presentado a la EPSI Anas Wayuu.

Tiempo estimado: Emisión del informe dentro de los 5 días hábiles posteriores a la reunión de cierre.

5.4.3 Aprobación y distribución del informe

El informe es revisado y aprobado por el Representante de la Dirección. Posteriormente, se distribuye a los responsables del proceso auditado y a las instancias que se definan en el SGSI.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	12 de 23		

Tiempo estimado: 2 días hábiles posteriores a la recepción del informe por parte del Representante de la Dirección.

5.5 FASE DE ACCIONES CORRECTIVAS Y SEGUIMIENTO

5.5.1 Elaboración de planes de acción por parte del proceso auditado

Los responsables del proceso auditado analizan los hallazgos y elaboran un plan de acción que incluya actividades, responsables, plazos y recursos necesarios para atender no conformidades y oportunidades de mejora. Este plan de acción se elabora de acuerdo al PD-860-16 Procedimiento de mejora continua, no conformidades y acciones correctivas.

Tiempo estimado: Presentación del plan de acción dentro de los 5 días hábiles posteriores a la recepción del informe.

5.5.2 Seguimiento a la implementación de acciones

El Auditor Líder, en coordinación con el Representante de la Dirección, realiza seguimiento periódico al avance de las acciones definidas, verificando el cumplimiento de los plazos y la disponibilidad de recursos.

Tiempo estimado: Seguimiento mensual o según criticidad del hallazgo.

5.5.3 Verificación de eficacia de las acciones correctivas

Una vez implementadas las acciones correctivas, el equipo auditor verifica su eficacia mediante revisión de evidencias, entrevistas o pruebas adicionales. Si las acciones no son eficaces, se solicitarán ajustes o nuevas acciones.

Tiempo estimado: Verificación dentro de los 30 a 60 días hábiles siguientes a la implementación, según criticidad.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	13 de 23		

5.6 FASE DE CIERRE DE LA AUDITORÍA

5.6.1 Actualización de registros y archivos de auditoría

El Auditor Líder asegura que todos los registros de la auditoría (plan, listas de verificación, evidencias, hallazgos, informes, planes de acción y seguimiento) se archiven en el repositorio oficial del SGSI, conforme al procedimiento de gestión documental.

Tiempo estimado: 1 día hábil.

5.6.2 Retroalimentación y mejora del proceso de auditoría

El Representante de la Dirección y el Auditor Líder analizan tendencias, dificultades y buenas prácticas identificadas durante la auditoría, proponiendo ajustes al procedimiento, formatos, criterios o métodos utilizados, para fortalecer el proceso en ciclos posteriores.

Tiempo estimado: Dentro de los 30 días hábiles posteriores al cierre de la auditoría.

6. CRITERIOS DE PRIORIZACIÓN DEL PROGRAMA ANUAL DE AUDITORÍAS

Para asegurar una asignación adecuada de recursos y un enfoque basado en riesgos, la EPSI Anas Wayuu definirá la priorización del programa anual de auditorías internas del SGSI aplicando los siguientes criterios:

a. Nivel de criticidad del proceso o activo de información:

- Procesos clasificados como *críticos* para la garantía de la prestación de servicios, aseguramiento, la atención al usuario, gestión del riesgo primario, gestión de cohortes.
- Activos de información con alta valoración en confidencialidad, integridad o disponibilidad.
- Controles del Anexo A asociados a riesgos altos o muy altos.

Justificación: Riesgos elevados requieren mayor supervisión para prevenir incidentes o incumplimientos.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	14 de 23		

b. Resultados de auditorías previas:

- Presencia de no conformidades mayores o repetitivas.
- Acciones correctivas sin cerrar o cuya eficacia esté pendiente por verificar.
- Áreas con antecedentes de incumplimiento recurrente.

Justificación: Procesos con bajo desempeño de control requieren mayor frecuencia de auditoría.

c. Cambios significativos en la EPSI o en los procesos auditados:

- Cambios en personal clave, estructura organizacional, tecnologías, proveedores, aplicativos o infraestructura.
- Implementación de nuevos sistemas de información o servicios asistenciales/digitales.
- Cambios en la interacción con el Ministerio de Salud, Supersalud, Contraloría, ADRES, SIC u otros entes de control.

Justificación: Los cambios pueden introducir nuevos riesgos o generar brechas de control.

d. Incidentes o eventos de seguridad relevantes:

- Incidentes de seguridad de alto impacto o repetitivos.
- Fallas relevantes en la continuidad del negocio, disponibilidad de servicios o violaciones de datos.
- Alertas de vulnerabilidad o amenazas emergentes aplicables al entorno de la EPSI.

Justificación: Se debe verificar la madurez del SGSI en áreas donde se han detectado vulnerabilidades.

e. Requisitos legales, regulatorios o contractuales:

- Obligaciones derivadas de normas como ISO/IEC 27001, Ley 1581, Decreto 1377, Resoluciones del Ministerio de Salud, entre otras.
- Requisitos contractuales con aliados estratégicos, proveedores tecnológicos o autoridades de salud.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	15 de 23		

- Renovación de certificaciones o evaluaciones externas.

Justificación: Cumplir la regulación y los compromisos contractuales requiere evaluar controles con mayor rigor.

f. Relevancia estratégica para la EPSI Anas Wayuu:

- Procesos clave como Gestión Estratégica, Gestión de la Calidad y Riesgos, Gestión Étnica y Cultural y Comunicaciones.
- Sistemas que soportan la toma de decisiones, el modelo de operación o los objetivos institucionales.
- Procesos que impactan la imagen, reputación o continuidad operativa de la EPSI.

Justificación: Mayor prioridad a procesos esenciales para la misión institucional.

g. Evaluación del riesgo residual del SGSI:

- Controles cuyo nivel de riesgo residual permanece alto o supera el nivel de aceptación definido por la EPSI.
- Riesgos con tendencia al incremento o con factores de amenaza emergente.

Justificación: Riesgos residuales elevados requieren verificación para asegurar mitigación efectiva.

h. Retroalimentación de partes interesadas:

- Solicitudes de áreas críticas (Gestión del Aseguramiento, Gestión del Riesgo en Salud, Tecnología, Asesoría Jurídica, Gestión Humana).
- Requerimientos de entes externos (Supersalud, entes territoriales, auditores externos).
- Necesidades detectadas por la alta dirección.

Justificación: Considera la percepción y necesidades internas y externas del sistema.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	16 de 23		

Para operacionalizar estos criterios, la EPSI Anas Wayuu utiliza MT-860-05 Matriz Priorización Auditorías, en la cual cada proceso, área o componente del SGSI es evaluado mediante una calificación numérica de 1 a 5 frente a los criterios definidos (criticidad, resultados de auditorías previas, cambios significativos, incidentes de seguridad, requisitos legales y regulatorios, relevancia estratégica y riesgo residual), aplicando además las ponderaciones establecidas para cada uno. El puntaje resultante permite clasificar objetivamente la prioridad de auditoría en alta, media o baja, garantizando que el enfoque del programa responda a los riesgos más relevantes y a las necesidades estratégicas del SGSI. Esta matriz se actualiza anualmente y forma parte de los registros del procedimiento, sirviendo como herramienta de soporte para la toma de decisiones y la planificación del programa anual de auditorías internas.

7. FRECUENCIA

La EPSI Anas Wayuu establecerá y mantendrá un programa anual de auditorías internas del SGSI cuya frecuencia estará determinada por el nivel de riesgo de los procesos, activos de información y controles asociados, así como por el desempeño histórico del sistema. Las auditorías deberán realizarse con una periodicidad mínima anual, garantizando que todos los procesos, dominios y controles del SGSI sean evaluados al menos una vez en cada ciclo de 12 meses.

Adicionalmente, la frecuencia podrá incrementarse para procesos o áreas que presenten:

- Resultados deficientes en auditorías previas.
- Cambios significativos en tecnología, estructura organizacional, servicios, proveedores o normativa aplicable.
- Incidentes de seguridad que afecten la confidencialidad, integridad o disponibilidad de la información.
- Implementación de nuevos sistemas, activos o controles críticos.
- Requisitos contractuales, regulatorios o solicitudes de la alta dirección.

De igual manera, podrán programarse auditorías extraordinarias cuando el responsable del SGSI lo considere pertinente para validar la eficacia de acciones correctivas, responder a incidentes relevantes o atender necesidades emergentes del sistema.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	17 de 23		

Todas las auditorías, ordinarias o extraordinarias, deberán documentarse formalmente en el formato FO-860-23 Programa de auditoría interna y contar con aprobación del Líder del SGSI.

8. RESPONSABILIDADES PARA LAS AUDITORÍAS INTERNAS

✓ Representante de la Dirección / Líder del SGSI

- Aprobar el programa anual de auditorías internas del SGSI.
- Designar al auditor líder interno o externo para cada auditoría.
- Garantizar la disponibilidad de recursos necesarios (tiempo, personal, información y acceso a sistemas).
- Hacer seguimiento a los resultados, acciones correctivas y oportunidades de mejora derivadas de las auditorías.
- Informar a la alta dirección sobre el desempeño del programa de auditorías y el estado de los hallazgos.

✓ Auditor Líder (interno o externo actuando en nombre de la EPSI)

- Planificar la auditoría, elaborar el plan de auditoría y comunicarlo a las partes interesadas pertinentes.
- Coordinar el equipo auditor y asignar responsabilidades específicas.
- Asegurar la aplicación del enfoque basado en riesgos durante la auditoría.
- Conducir las reuniones de apertura y cierre.
- Validar la evidencia recopilada y determinar los hallazgos finales.
- Elaborar el informe de auditoría y remitirlo al Representante de la Dirección/Líder del SGSI en los tiempos establecidos.
- Verificar la implementación y eficacia de las acciones tomadas frente a las no conformidades y observaciones.

Nota: Cuando actúe un auditor líder externo, deberá garantizar independencia, confidencialidad y ausencia de conflicto de interés, cumpliendo los mismos requisitos de los auditores internos.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	18 de 23		

✓ **Equipo Auditor (interno o externo)**

- Preparar la auditoría revisando documentos, políticas, procedimientos y controles aplicables.
- Realizar entrevistas, revisión documental y verificación in situ de evidencias.
- Registrar evidencias objetivas de manera completa y verificable.
- Reportar hallazgos al auditor líder para su consolidación.
- Mantener en todo momento la confidencialidad de la información revisada.

Nota: Los auditores externos que integren el equipo auditor deben firmar acuerdos de confidencialidad y cumplir con las directrices del SGSI de la EPSI.

✓ **Auditados (áreas, procesos, proveedores o responsables de activos)**

- Facilitar el acceso a la información, sistemas, registros y personal requerido por el equipo auditor.
- Atender con oportunidad las entrevistas y solicitudes de evidencia.
- Analizar los hallazgos y proponer acciones correctivas cuando aplique.
- Implementar acciones correctivas y evidenciar su eficacia dentro de los plazos establecidos.

✓ **Proceso de Gestión Humana / Gestión de la Calidad y Riesgos**

- Mantener actualizados los registros de competencia y formación de los auditores internos.
- Asegurar la disponibilidad y gestión de los documentos y registros generados en el proceso de auditoría.

✓ **Proveedores Externos Auditados (si participan en el tratamiento de información)**

- Garantizar la entrega oportuna de la información y evidencias requeridas.
- Cumplir los acuerdos contractuales relacionados con auditorías y seguridad de la información.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	19 de 23		

- Atender las acciones correctivas derivadas de los hallazgos que afecten la prestación del servicio.

9. DISPOSICIONES FINALES

El presente procedimiento constituye la guía oficial para la planificación, ejecución, documentación y seguimiento de las auditorías internas del Sistema de Gestión de Seguridad de la Información (SGSI) de la EPSI Anas Wayuu. Su correcta aplicación garantiza que las auditorías se realicen de manera sistemática, objetiva y basada en riesgos, contribuyendo a fortalecer la confianza en el desempeño del SGSI, a identificar áreas críticas de mejora y a verificar la eficacia de los controles implementados.

El cierre del procedimiento implica la consolidación de todos los registros generados durante el proceso auditor —incluidos el plan de auditoría, listas de verificación, evidencias recopiladas, informes, planes de acción y resultados de seguimiento— los cuales deben ser gestionados conforme a las políticas de gestión documental y preservación de la información de la EPSI Anas Wayuu. Asimismo, el cierre formal del procedimiento reafirma el compromiso institucional con la mejora continua, permitiendo que las lecciones aprendidas, los hallazgos recurrentes y las oportunidades identificadas alimenten la actualización del programa de auditorías, los controles del SGSI y las estrategias de seguridad de la información de la organización.

Finalmente, este procedimiento deberá revisarse y actualizarse periódicamente o cuando ocurran cambios relevantes en los requisitos normativos, en la estructura organizacional, en los riesgos del SGSI o en la retroalimentación derivada de su aplicación, garantizando que continúe siendo pertinente, eficaz y alineado con los principios de seguridad de la información y con las necesidades estratégicas de la EPSI Anas Wayuu.

10. ENTRADAS

- ✓ Programa Anual de Auditorías Internas del SGSI.
- ✓ Matriz de Priorización de Auditorías.
- ✓ Documentación del SGSI.
- ✓ Resultados de auditorías internas y externas.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	20 de 23		

11. MATERIALES NECESARIOS

- ✓ Oficinas administrativas al interior de la entidad.
- ✓ Muebles de oficina.
- ✓ Herramientas de oficina (grapadora, saca grapas, perforadora, entre otros).
- ✓ Teléfono o celular.
- ✓ Archivadores.
- ✓ Computadores.
- ✓ Aplicaciones de apoyo.
- ✓ Internet.
- ✓ Conexiones periféricas.
- ✓ Impresora.
- ✓ Papelería (hojas, notas adhesivas, bloc de notas, agenda, entre otros).

12. PRODUCTOS O RESULTADOS ESPERADOS

- ✓ Informe de Auditoría Interna.
- ✓ Planes de acción.
- ✓ Reporte de lecciones aprendidas.
- ✓ Documentación actualizada del SGSI.

13. DOCUMENTOS Y REGISTROS

- ✓ FO-860-25-Lista de verificación de auditorías
- ✓ FO-860-22-Informe de auditoría Interna.
- ✓ MT-860-05 Matriz Priorización Auditorías.
- ✓ PD-860-16 Procedimiento de mejora continua, no conformidades y acciones correctivas.
- ✓ FO-860-23 Programa de auditoría interna.

14. RESPONSABLE POR LA SOCIALIZACIÓN DE ESTOS PROCESOS

- ✓ Representante de la Dirección / Líder del SGSI.
- ✓ Auditor Líder.
- ✓ Equipo Auditor (interno o externo).
- ✓ Oficina Gestión Humana.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	21 de 23		

- ✓ Gestión de la Calidad y Riesgos.

15. RESPONSABLES POR LA EJECUCIÓN

- ✓ Representante de la Dirección / Líder del SGSI.
- ✓ Auditor Líder.
- ✓ Equipo Auditor (interno o externo).
- ✓ Auditados (áreas, procesos, proveedores o responsables de activos).
- ✓ Proceso de Gestión Humana / Gestión de la Calidad y Riesgos.
- ✓ Proveedores Externos Auditados (si participan en el tratamiento de información).

16. CONTROL DE CAMBIOS

VERSION	PAGINAS	FECHA DE CREACIÓN	FECHA DE ACTUALIZACIÓN	DESCRIPCIÓN DE CAMBIOS
1.0	Veintitrés (23)	02/05/2025	N/A	Creación.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	22 de 23		

17. ANEXO

Perfil: Auditor Líder - EPSI Anas Wayuu

CATEGORÍA	DESCRIPCIÓN
Educación	Profesional en Ingeniería de Sistemas, Telecomunicaciones, Industrial o áreas afines. Deseable posgrado en Seguridad de la Información, Auditoría, Gestión de Riesgos o Sistemas Integrados de Gestión.
Formación	Certificación Auditor Líder ISO/IEC 27001:2022. Deseable formación en auditoría ISO 9001, ISO 22301, ISO 27701 o similares.
Experiencia Laboral General	Mínimo 5 años de experiencia en TI, seguridad de la información, gestión de riesgos o sistemas de gestión.
Experiencia Específica en Auditorías	Al menos 30 días de auditorías realizadas (equivalentes a 240 horas). De estas, mínimo 15 días como auditor líder (120 horas).
Competencias Técnicas	Dominio de ISO/IEC 27001:2022 e ISO/IEC 27002:2022; gestión de riesgos ISO/IEC 27005; deseables conocimientos en ciberseguridad; análisis de vulnerabilidades; gestión documental; interpretación de requisitos normativos; modelado de procesos; uso de herramientas como SIEM, GRC, suites de auditoría y plataformas de gestión.
Competencias Blandas	Liderazgo, comunicación asertiva, pensamiento analítico, resolución de conflictos, gestión del tiempo, escucha activa y manejo de grupos interculturales.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo

Código:	PD-860-12	PROCEDIMIENTO DE AUDITORÍA INTERNA	
Versión:	1.0-02-05-25		
Página:	23 de 23		

Perfil: Auditor Interno - EPSI Anas Wayuu

CATEGORÍA	DESCRIPCIÓN
Educación	Tecnólogo o profesional en Sistemas, Administración, Ingeniería o áreas afines.
Formación	Curso de Auditor Interno ISO/IEC 27001:2022. Deseable formación complementaria en ISO 9001, gestión de riesgos o ciberseguridad.
Experiencia Laboral General	Mínimo 2 años en actividades de TI, seguridad de la información, soporte o procesos organizacionales.
Experiencia Específica en Auditorías	Al menos 10 días de participación en auditorías internas (80 horas).
Competencias Técnicas	Conocimientos en ISO/IEC 27001:2022; mapeo de procesos; elaboración de listas de verificación; identificación de hallazgos; análisis básico de riesgos; manejo de documentos del SGSI; deseables conocimientos iniciales en ciberseguridad y controles ISO/IEC 27002.
Competencias Blandas	Trabajo en equipo, atención al detalle, comunicación efectiva, ética profesional, pensamiento crítico y orientación a resultados.

Elabora:	Revisa:	Aprueba:
Coordinador de Sistemas Integrados de Calidad	Director de Aseguramiento y Tecnología	Consejo Directivo